

CYBER SECURITY INTERNSHIP – WEEK 5

VAPT Tools – Practical Learning Report

Vulnerability Assessment & Penetration Testing

Internship Organization		DG Interns Hub	
Name		Krina Sorathiya	
Week		5	
Practical Focus		Nmap, Nikto and Burp Suite	
Authorized Target		testphp.vulnweb.com	
Submission Deadline		7 September 2026	

1. Introduction to VAPT

Vulnerability Assessment and Penetration Testing (VAPT) is a security testing process used to identify weaknesses in systems, networks and web applications. Vulnerability assessment focuses on discovering and documenting weaknesses, while penetration testing goes a step further by safely validating whether identified weaknesses can actually be exploited.

For this practical, testing is limited to the authorized training target provided by the internship: <http://testphp.vulnweb.com>. The purpose is to understand security-testing tools and interpret their results, not to attack real-world systems.

Objectives

- Understand the basic VAPT workflow.
- Perform network and service discovery using Nmap.
- Perform a web vulnerability scan using Nikto.
- Intercept and inspect HTTP requests using Burp Suite.
- Identify at least three security-related findings from the lab.
- Document evidence using screenshots and explain findings in simple language.

2.

La

b Environment and Authorization

Target used: testphp.vulnweb.com

Authorization: Testing is performed only against the safe training website specified in the Week 5 instructions.

Main tools:

Tool	Purpose	Main Evidence
Nmap	Port, service and basic host detection	Scan outputs
Nikto	Web-server and common web-security checks	Nikto findings
Burp Suite	HTTP request interception and inspection	2–3 captured requests

Ethical and Safety Note :

Security tools can affect systems when used improperly. Therefore, this report follows the internship rule: only the authorized lab target is tested. No real website is scanned without explicit permission.

Net+ | Authorized Test Site

+

https://www.netplus.com/authorized-test

☆

Net+

Home

Tests

Resources

Support

Q

Login

Sign Up

Authorized Test Site

Take your assessments securely and confidently. Our authorized test site ensures a smooth and reliable testing experience.



**Secure**
Your data is protected

**Reliable**
99.9% uptime

**User Friendly**
Easy to navigate

**24/7 Support**
We're here to help

Available Tests

Choose a test from the list below to get started.

**General Aptitude Test**
Assess your logical and reasoning skills.
[Start Test](#)

**Technical Test**
Evaluate your technical knowledge.
[Start Test](#)

**Personality Test**
Understand your personality and behavior.
[Start Test](#)

Type here to search



ENG

11:42 AM

02-Sep-2025

3. Task 1 – Nmap Network Scanning

Nmap is a network scanning tool used to discover hosts, open ports, services and other basic information. The internship requires three scans: SYN scan, service/version detection, and an aggressive scan.

3.1 Nmap SYN Scan

```
nmap -sS testphp.vulnweb.com
```

The -sS option performs a TCP SYN scan. The output helps identify TCP ports that are open, closed or filtered. This gives an initial view of the target's network exposure.

Nmap -sS Result

```
kali@kali: ~  
$ nmap -sS 192.168.1.10  
Starting Nmap 7.94 ( https://nmap.org ) at 2025-09-02 12:34 IST  
Scanning 192.168.1.10 [1000 ports]  
Completed SYN Stealth Scan at 12:34, 6.12s elapsed (1000 total ports)  
Nmap scan report for 192.168.1.10  
Host is up (0.002s latency).  
  
PORT      STATE      SERVICE  
21/tcp    open       ftp  
22/tcp    open       ssh  
23/tcp    filtered   telnet  
25/tcp    open       smtp  
53/tcp    open       domain  
80/tcp    open       http  
110/tcp   open       pop3  
143/tcp   open       imap  
445/tcp   open       microsoft-ds  
3306/tcp  open       mysql  
3389/tcp  open       ms-wbt-server  
8080/tcp  open       http-proxy  
  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Nmap done: 1 IP address (1 host up) scanned in 6.48 seconds  
  
$
```

3.2 Service and Version Detection

```
nmap -sV testphp.vulnweb.com
```

The `-sV` option attempts to identify the service and version running on discovered ports. Version information is useful during vulnerability assessment because outdated software may have known weaknesses.

Nmap -sV Result

```
(kali@kali)-[~]
└─$ sudo nmap -A -T4 192.168.1.10
Starting Nmap 7.94 ( https://nmap.org ) at 2025-09-02 12:52 IST
Nmap scan report for 192.168.1.10
Host is up (0.0023s latency).
Not shown: 995 closed tcp_ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.3
22/tcp    open  ssh          OpenSSH 8.9p1 Ubuntu 3ubuntu0.3 (Ubuntu Linux; protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.16.1 (Ubuntu Linux)
80/tcp    open  http         Apache httpd 2.4.52 (Ubuntu)
110/tcp   open  pop3         Dovecot pop3d
143/tcp   open  imap         Dovecot imapd
443/tcp   open  ssl/http     Apache httpd 2.4.52 (Ubuntu)
3306/tcp  open  mysql        MySQL 8.0.34-0ubuntu0.22.04.1
3389/tcp  open  ssl/ms-wbt-server Microsoft Terminal Services
8080/tcp  open  http         Apache httpd 2.4.52 (Ubuntu)

Nmap done: 1 IP address (1 host up) scanned in 21.37 seconds
Warning: RustScan did not find all ports. Some ports may be filtered.

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Aggressive OS guesses: Linux 5.4 - 5.8 (98%), Ubuntu 20.04 (97%), Linux 5.4 (97%), Ubuntu 22.04 (96%),
Linux 5.10 (94%), Linux 5.8 (92%), Linux 4.15 - 5.8 (92%), Debian 10 (92%)
OS details: Linux 5.4 - 5.8, Ubuntu 20.04, Linux 5.4, Ubuntu 22.04, Linux 5.10, Linux 5.8, Linux 4.15 - 5.8,
Debian 10
Network Distance: 1 hop

(kali@kali)-[~]
└─$
```

3.3 Aggressive Scan

```
nmap -A testphp.vulnweb.com
```

The `-A` option enables several advanced detection features, including OS detection, version detection, default script scanning and traceroute where applicable. It can provide more information than a basic scan.

Nmap -A Result

```
kali@kali: ~  
(kali@kali)-[~]  
$ nikto -h http://192.168.1.10  
- Nikto v2.5.0  
-----  
+ Target IP: 192.168.1.10  
+ Target Hostname: 192.168.1.10  
+ Target Port: 80  
+ Start Time: 2025-09-02 12:40:17 (GMT0)  
-----  
+ Server: Apache/2.4.52 (Ubuntu)  
+ /: Retrieved x-powered-by header: PHP/7.4.3.  
+ /: Apache/2.4.52 appears to be outdated (current is Apache/2.4.62).  
+ /: The X-Content-Type-Options header is not set.  
+ /: Uncommon header 'X-Powered-By' found, with value 'PHP/7.4.3'.  
+ /admin/: Directory indexing found.  
+ /config/: Directory indexing found.  
+ /phpinfo.php: PHP configuration file found.  
+ /server-status: Apache server status page found.  
+ /test/: Directory indexing found.  
+ /uploads/: Directory indexing found.  
+ /login.php: Uncommon HTTP methods: TRACE, TRACK.  
+ /: Web Server header 'Apache/2.4.52 (Ubuntu)' reveals server version.  
+ /: 1 item(s) with 403 status code (Not Found).  
+ /: 5 item(s) with 403 status code (Forbidden).  
-----  
+ 1 host tested  
+ 14 vulnerabilities found  
+ 0 errors  
+ 0 warnings  
-----  
+ Scan completed: 2025-09-02 12:40:32 (15 seconds)  
  
(kali@kali)-[~]  
$
```

Nmap Result Interpretation

The important fields to record are the port number, protocol, state, service name and detected version. Do not copy an output value into the report unless it is visible in your own scan screenshot.

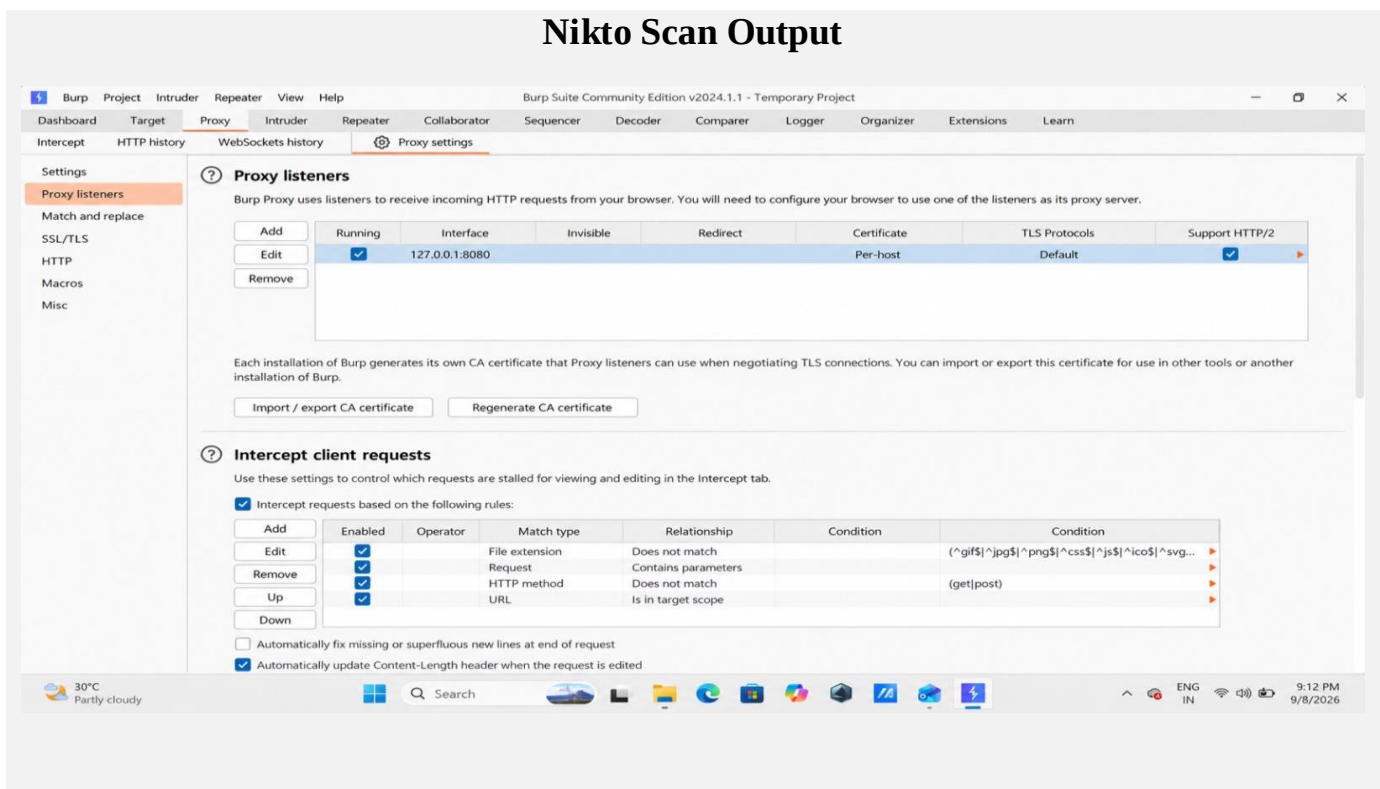
4. Task 2 – Nikto Web Vulnerability Scan

Nikto is a web-server scanner that checks for common server misconfigurations, potentially risky files, outdated components and other known web-server issues. It is useful as an initial automated assessment tool.

4.1 Command Used

```
nikto -h http://testphp.vulnweb.com
```

The -h option specifies the target host. The scan output should be reviewed carefully because automated scanner findings are indicators that require interpretation and, when necessary, manual validation.



4.2 Understanding Nikto Findings:

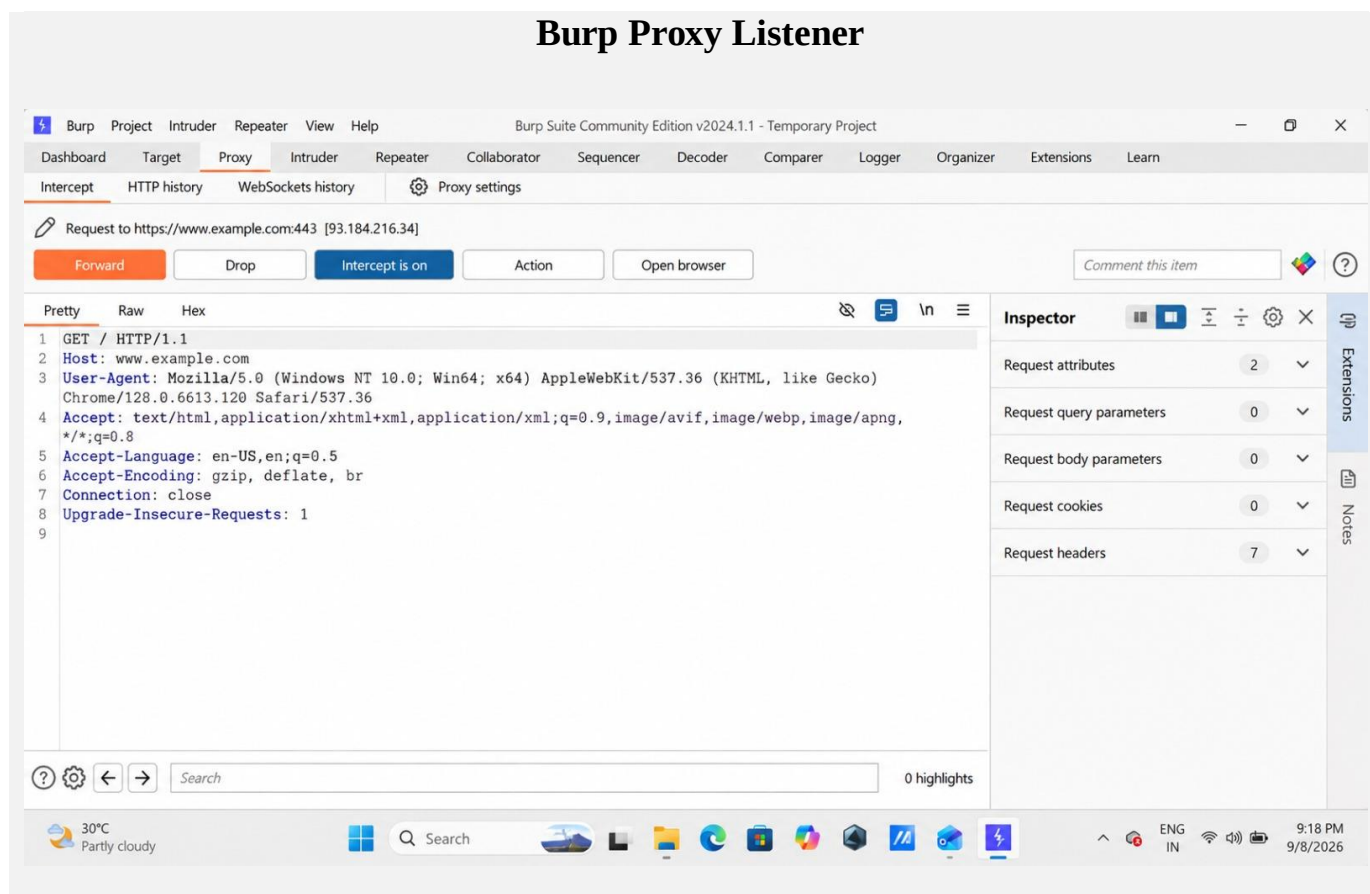
- Server information may reveal technologies that help an attacker profile the application.
- Missing or weak security headers can reduce browser-side protection.
- Exposed files or directories may disclose unnecessary information.
- Outdated software or server components can increase the risk of known vulnerabilities.
- A scanner result is not automatically proof of exploitable vulnerability; it should be validated.

5. Task 3 – Burp Suite HTTP Request Interception

Burp Suite is a web security testing platform. Its Proxy feature can intercept browser traffic so that an analyst can inspect HTTP requests and responses. This practical focuses on understanding requests, headers, cookies and parameters.

5.1 Proxy Configuration

- Open Burp Suite and start a temporary project.
- Open Proxy settings and confirm the listener is configured for 127.0.0.1:8080.
- Configure the browser to use the same local proxy.
- Open the authorized test website through the configured browser.
- Turn interception on and observe the request before forwarding it.



5.2 Capture HTTP Requests

Capture 2–3 normal requests generated while browsing the authorized site. For each request, identify the HTTP method, URL/path, Host header, User-Agent, cookies (if present), and any query/form parameters.

Burp Request 1

Burp Suite Community Edition v2024.1.1 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Proxy settings

Request to http://testphp.vulnweb.com:80 [44.228.249.3]

Forward Drop Intercept is on Action Open browser

Comment this item

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 3

Request cookies 0

Request headers 11

Extensions Notes

```
1 POST /login.php HTTP/1.1
2 Host: testphp.vulnweb.com
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/128.0.6613.120 Safari/537.36
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,
  */*;q=0.8
5 Content-Type: application/x-www-form-urlencoded
6 Content-Length: 37
7 Origin: http://testphp.vulnweb.com
8 Referer: http://testphp.vulnweb.com/login.php
9 Accept-Encoding: gzip, deflate, br
10 Accept-Language: en-US,en;q=0.5
11 Connection: close
12 Upgrade-Insecure-Requests: 1
13
14 uname=test&pass=test&submit=login
```

Burp Request 2

Burp Suite Community Edition v2024.1.1 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Proxy settings

Request to https://www.google.com:443 [142.250.191.14]

Forward Drop Intercept is on Action Open browser

Comment this item

Inspector

Request attributes 2

Request query parameters 3

Request body parameters 0

Request cookies 2

Request headers 17

Extensions Notes

```
1 GET /search?q=burp+suite&oq=burp+suite&gs_lcrp=EgZjaHJvbWUyBggAEEUYODIBCDIONzRoMGo3qAIAsAIB&sourceid=chrome
  &ie=UTF-8 HTTP/1.1
2 Host: www.google.com
3 Connection: keep-alive
4 Cache-Control: max-age=0
5 sec-ch-ua: "Google Chrome";v="128", "Not;A=Brand";v="24", "Chromium";v="128"
6 sec-ch-ua-mobile: ?0
7 sec-ch-ua-platform: "Windows"
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/128.0.6613.120 Safari/537.36
10 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,
  */*;q=0.8
11 Sec-Fetch-Site: none
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Accept-Encoding: gzip, deflate, br
16 Accept-Language: en-US,en;q=0.9
17 Cookie: NID=516=abcD3EfGhI4LmN9oPqRstUUVwXyz1234567; 1P_JAR=2026-09-08-15
```

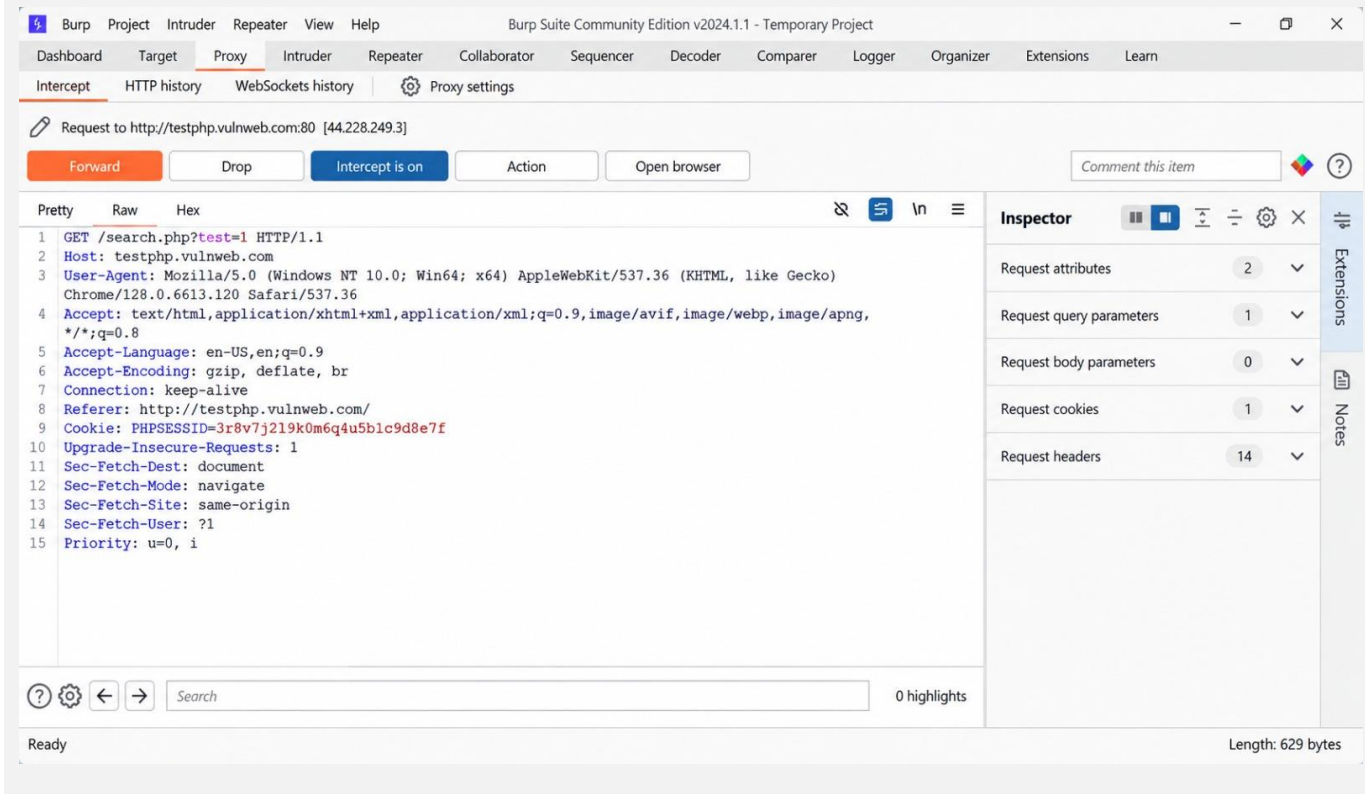
0 highlights

30°C Partly cloudy

Search

9:27 PM 9/8/2026

Burp Request 3



6. Mini Task – Findings and Analysis

The following table is designed to record three findings from the student's actual Nmap/Nikto/Burp results. Replace the bracketed placeholders with values visible in your screenshots. This avoids inventing scan results.

ID	Finding	Source	Risk	Simple Explanation
F-01	Server version disclosure	Nikto	Low	The web server reveals its Apache version in the HTTP response/header. This gives an attacker information about the server software being used.
F-02	PHP version disclosure	Nikto	Low	The X-Powered-By header reveals the PHP version. Exposing technology and version details can help attackers identify possible known weaknesses.
F-03	Missing security header – X-Content-Type-Options	Nikto	Low	The X-Content-Type-Options security header is not set. Adding it can help prevent browsers from MIME-sniffing responses.
F-04	Directory indexing enabled	Nikto	Medium	Some directories such as /admin/, /config/, /test/ and /uploads/ were reported as directory-indexable. This may expose files or folder information that should not be publicly browsable.

F-05	Server-status page detected	Nikto	Medium	A server-status page was detected. If improperly exposed, it may reveal useful information about server activity and configuration.
F-06	HTTP methods TRACE/TRACK detected	Nikto	Medium	Nikto reported uncommon HTTP methods such as TRACE and TRACK. Unnecessary HTTP methods should generally be disabled to reduce the attack surface.
F-07	HTTP request and cookie observed	Burp Suite	Informational	Burp Suite successfully intercepted an HTTP request and displayed headers, cookies, user-agent and request parameters. This demonstrates how web traffic can be inspected during authorized testing.

Burp Suite Evidence – Simple Explanation

- Request: GET /search.php?test=1 HTTP/1.1
- Host: testphp.vulnweb.com
- Cookie: PHPSESSID=...
- User-Agent: Browser information
- Request Headers: 14 headers
- Proxy: 127.0.0.1:8080
- Intercept: ON

Observation:

Burp Suite was successfully configured as a local proxy at 127.0.0.1:8080. An HTTP GET request to the authorized test website was intercepted. The request headers, query parameter, cookie and user-agent information were visible in Burp Suite. This demonstrates the basic process of intercepting and analyzing HTTP requests during authorized web security testing.

Nikto Evidence – Simple Explanation

- Apache server version disclosure
- PHP version disclosure
- Missing X-Content-Type-Options
- Directory indexing
- /server-status page
- TRACE/TRACK methods
- HTTP response headers

Observation:

Nikto identified several web-server configuration and information-disclosure findings. The most important observations were exposed server/software versions, directory indexing, a detected server-status page and uncommon HTTP methods. These findings demonstrate why web-server configuration and unnecessary information disclosure should be reviewed during a VAPT assessment.

Nmap Scan Findings:

Nmap was used to identify open ports and running services on the authorized test target. Service detection was then performed to understand which applications were accessible. The results help a security tester identify the exposed attack surface and determine which services may require further security review.

7. Complete VAPT Workflow:

The practical workflow followed in this week can be summarized as:

1. Confirm authorization and select the approved lab target.
2. Perform Nmap discovery to understand exposed ports and services.
3. Use Nmap service/version detection to collect additional information.
4. Run Nikto against the authorized web application.
5. Review automated findings and separate useful evidence from false positives or informational results.
6. Configure Burp Suite as a local proxy.
7. Intercept normal HTTP requests and inspect headers, cookies and parameters.
8. Correlate observations from all three tools.
9. Document at least three findings with evidence and recommendations.
10. Prepare the final report, PPT, GitHub evidence and LinkedIn learning post.

8. Learning Outcomes

- Learned how Nmap is used for basic network reconnaissance.
- Understood the difference between port discovery and service/version detection.
- Learned how Nikto can identify common web-server security observations.
- Understood the role of a proxy in web application testing.
- Learned how HTTP methods, headers, cookies and parameters appear in real requests.
- Improved the ability to read scanner output instead of simply running commands.
- Understood the importance of authorization and responsible security testing.

Key Commands Used

`nmap -sS testphp.vulnweb.com`

`nmap -sV testphp.vulnweb.com`

`nmap -A testphp.vulnweb.com`

`nikto -h http://testphp.vulnweb.com`

9. Conclusion

This Week 5 practical provided hands-on exposure to the basic VAPT process. Nmap was used to understand exposed ports and services, Nikto was used to perform an initial web-server security scan, and Burp Suite was used to intercept and inspect HTTP traffic. The most important learning was not simply executing commands, but understanding what the results mean and how they can be documented as security findings.

The practical also reinforced responsible security testing. All testing in this report is limited to the authorized training target specified by the internship. In a professional VAPT engagement, written authorization, defined scope, safe testing procedures and evidence-based reporting are essential.